



Criticalops

Date: 12nd December 2023
Prepared By: `lordrukie`
Challenge Author(s): `lordrukie`
Difficulty: Very Easy
Classification: Official

Synopsis

Criticalops is a very easy web challenge where players inspect client-side JavaScript and source maps to recover a JWT signing secret, forge an admin token, and access the admin panel to retrieve the flag.

Description

Criticalops is a web application designed to monitor critical infrastructure in the XYZ region. Users usually use this website to report unusual behavior through tickets. They've asked you to hunt for potential security issues in their application and retrieve the flag stored in their site.

Good luck, and thank you for your participation!

Skills Required

- Browser developer tools usage
- Basic understanding of JWT structure and claims
- Familiarity with client-side JavaScript inspection

Skills Learned

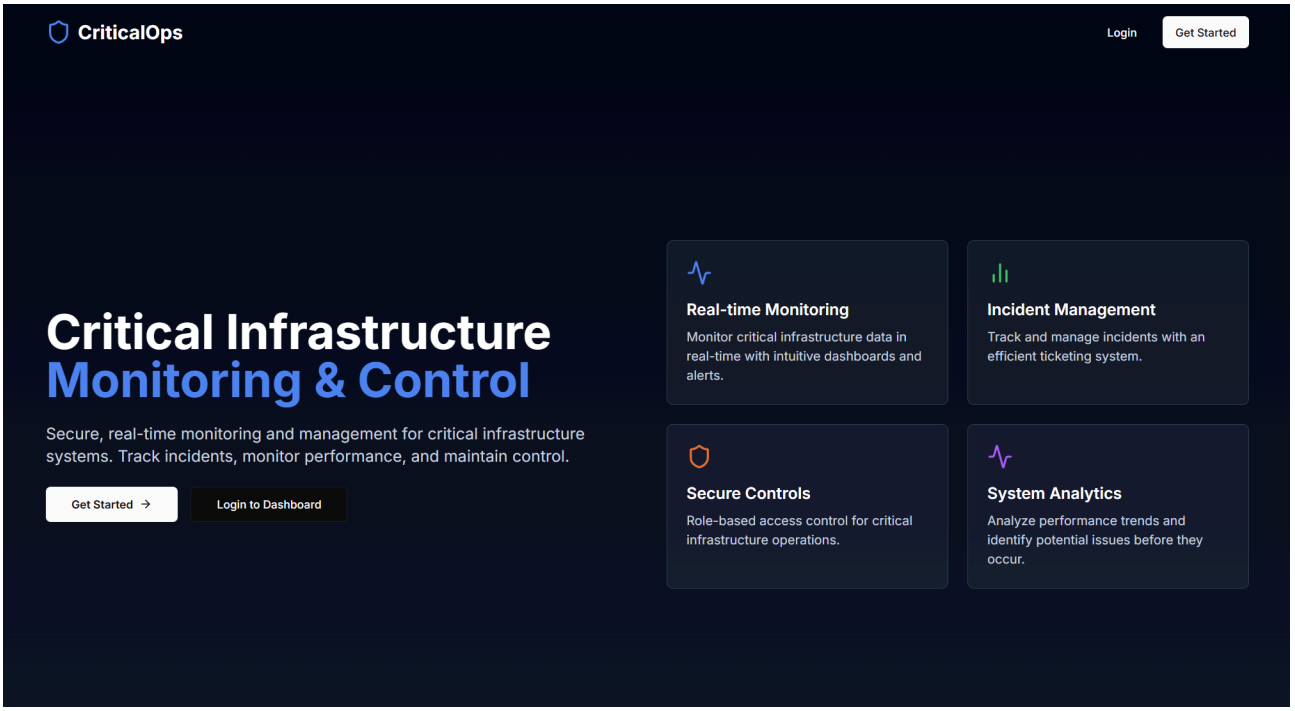
- Identifying exposed JWT secrets in bundled frontend code
- Using source maps to recover client-side authorization logic
- Forging JWT role claims with a recovered signing secret

- Gaining admin access by placing forged tokens in browser storage

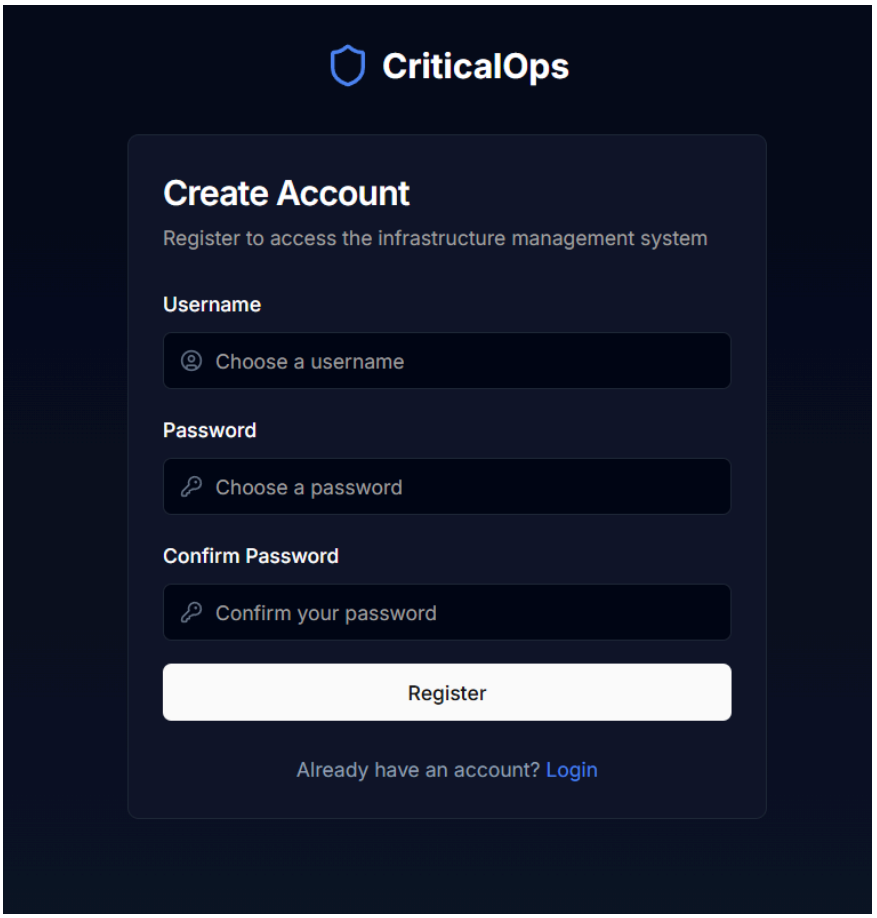
Solution

How to Solve

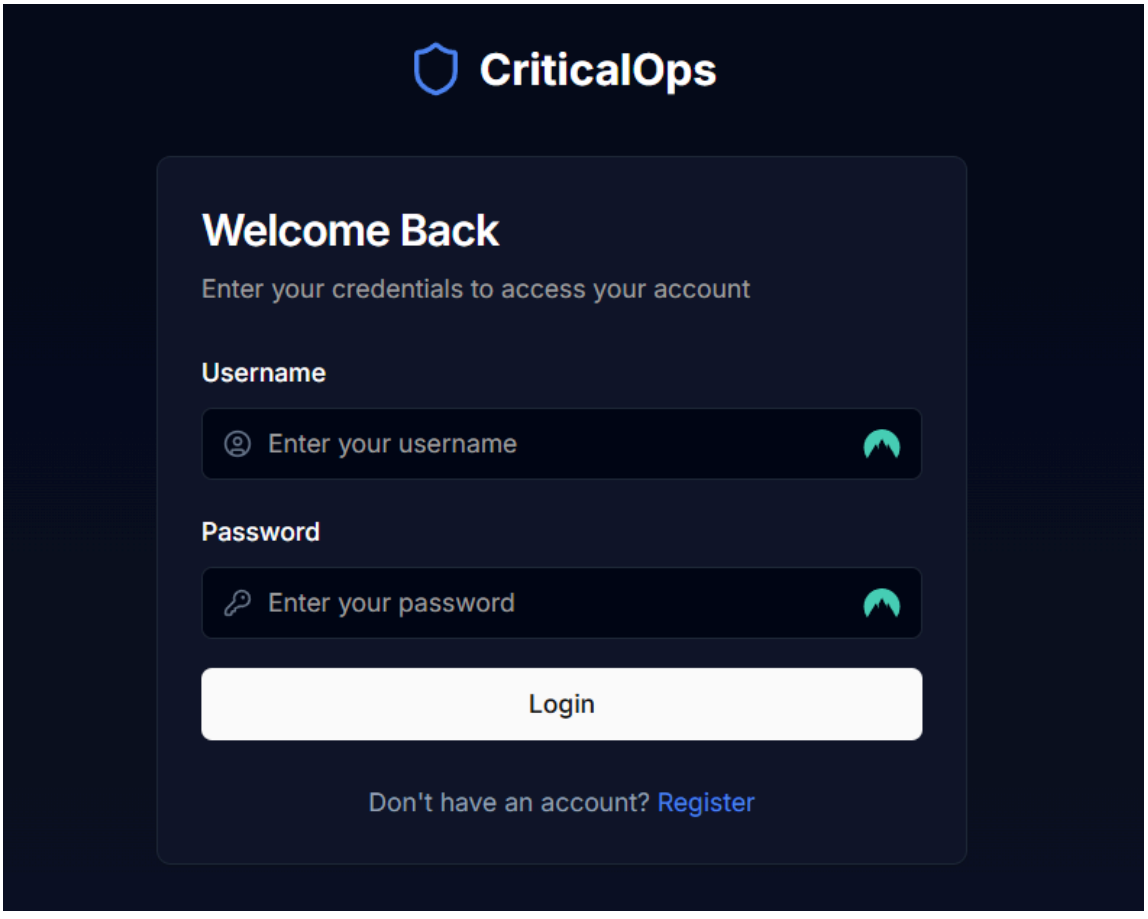
In this challenge, users are presented with a web application designed to control and monitor critical infrastructure:



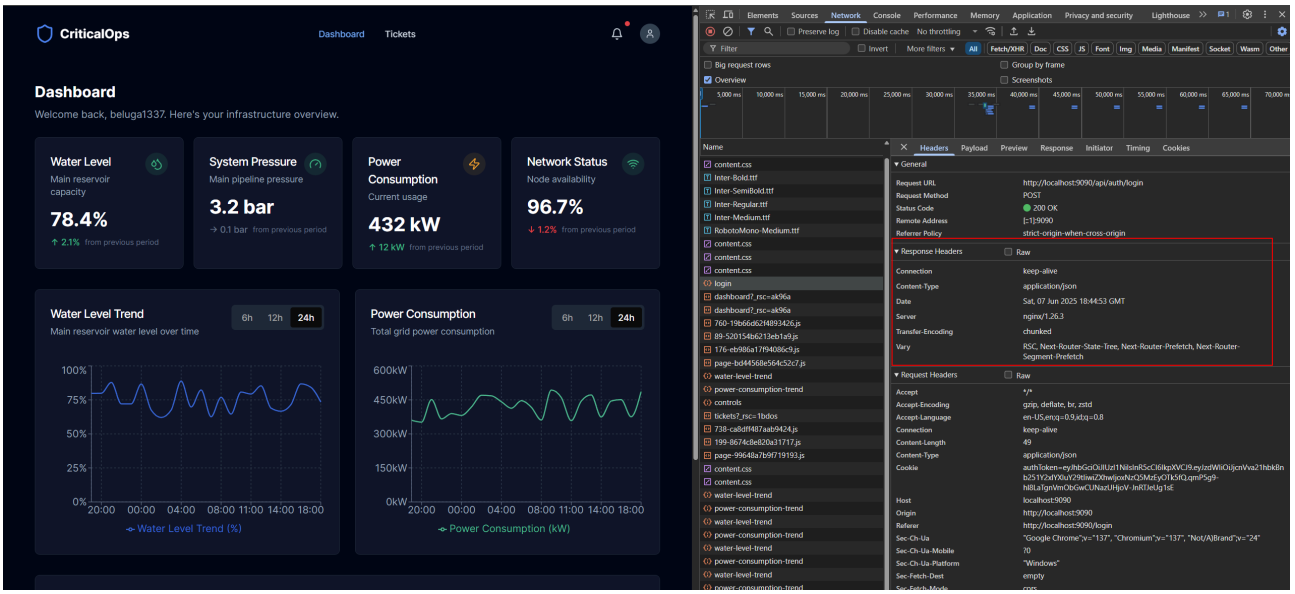
Users can register:

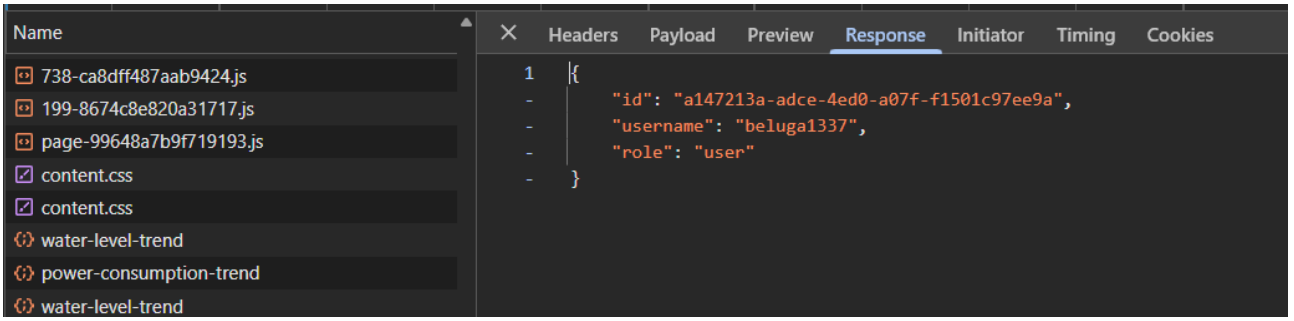

CriticalOps
Create Account
Register to access the infrastructure management system
Username
Choose a username
Password
Choose a password
Confirm Password
Confirm your password
Register
Already have an account? Login

...and log in:

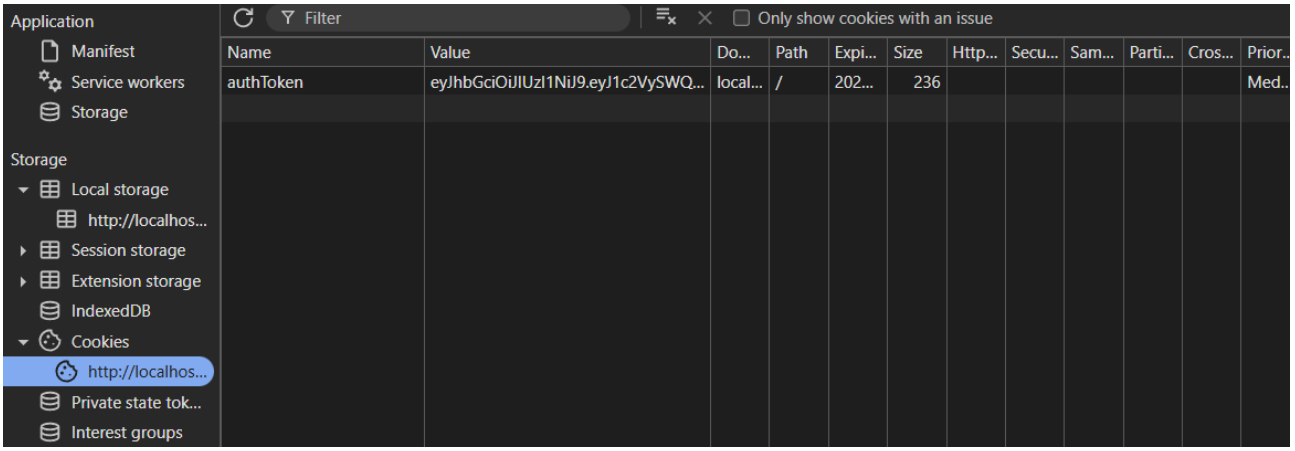

CriticalOps
Welcome Back
Enter your credentials to access your account
Username
Enter your username
Password
Enter your password
Login
Don't have an account? Register

After registering and logging in, no authentication cookies or tokens are initially set:

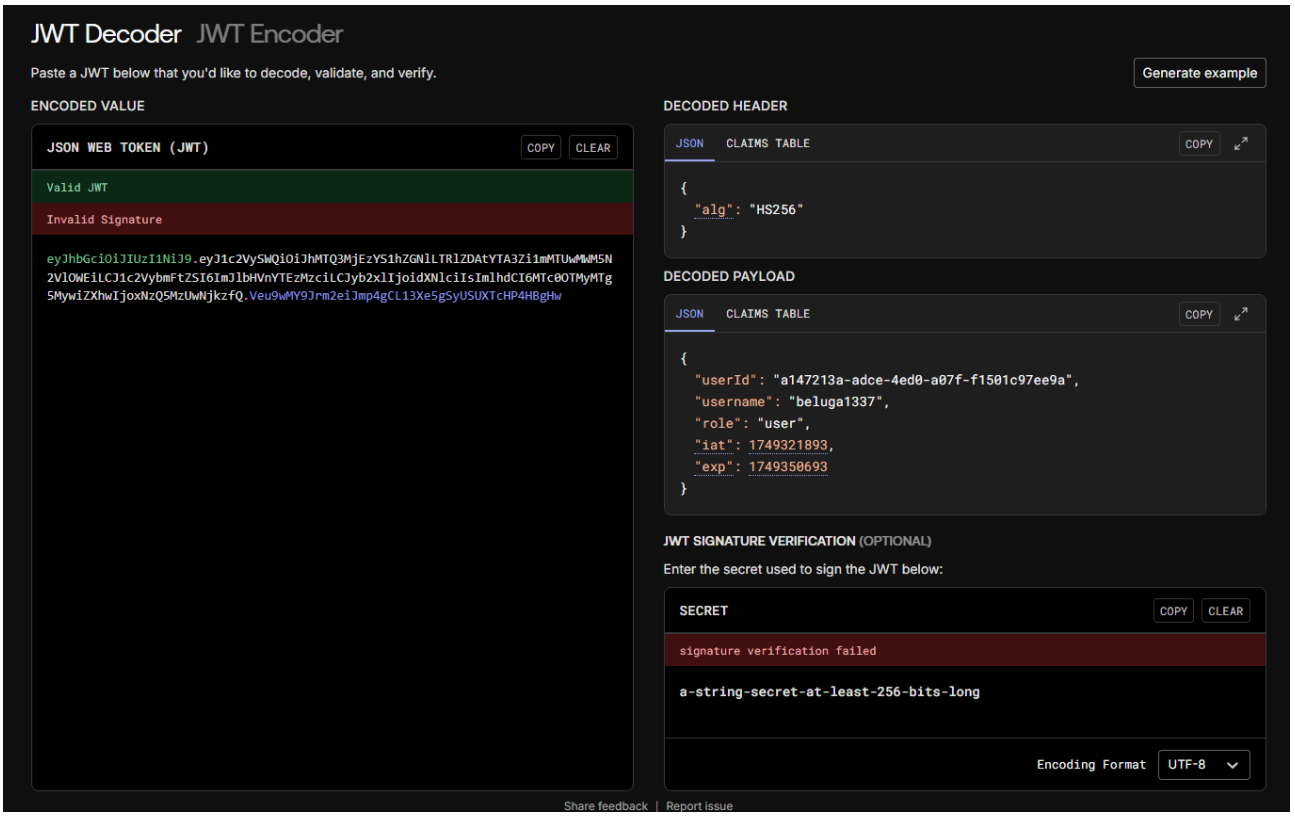




However, shortly after interacting with the app, a new token appears in the browser's Local Storage, named `authToken`:

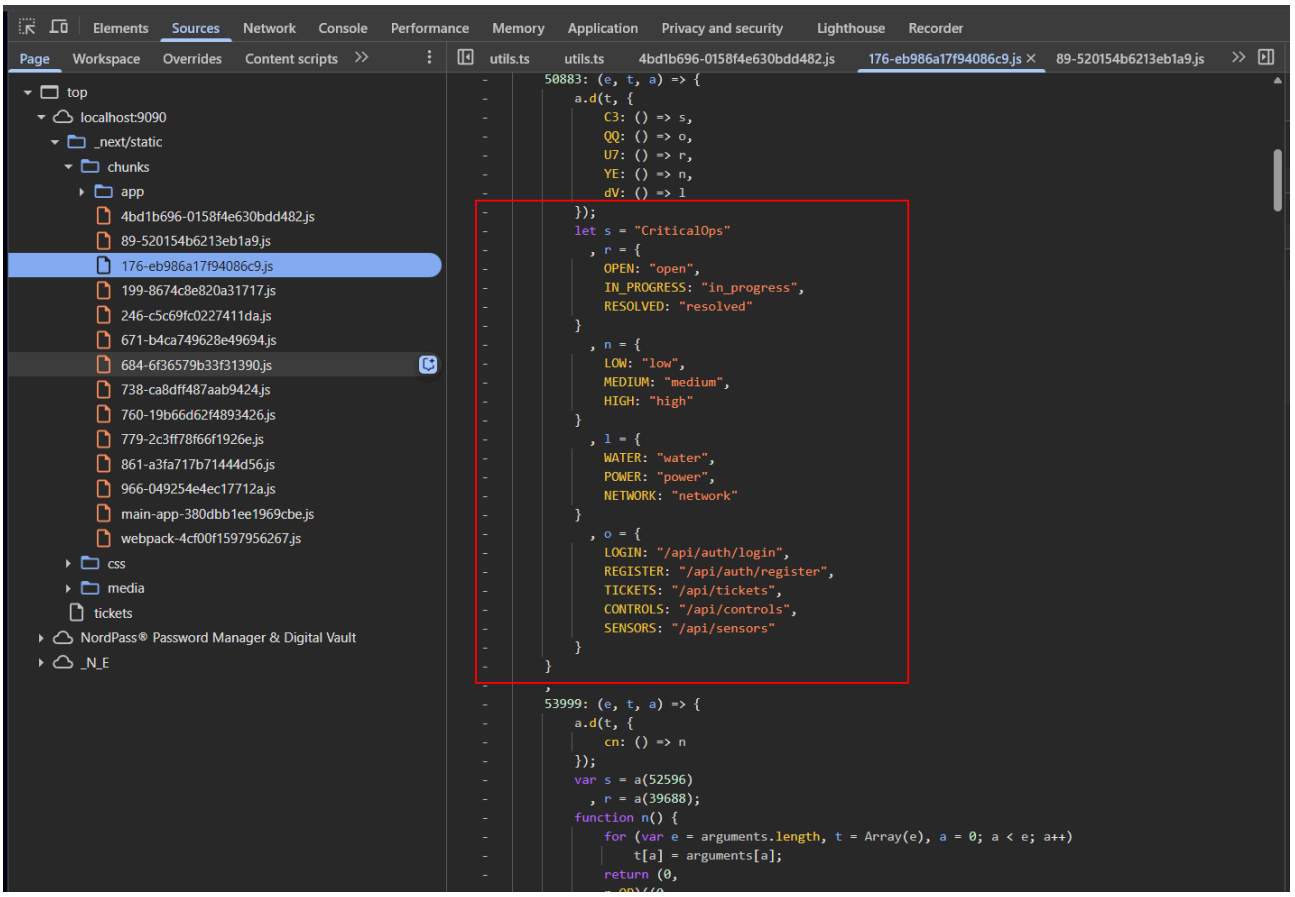


Decoding the JWT shows that it contains a role field, indicating a role-based access system:

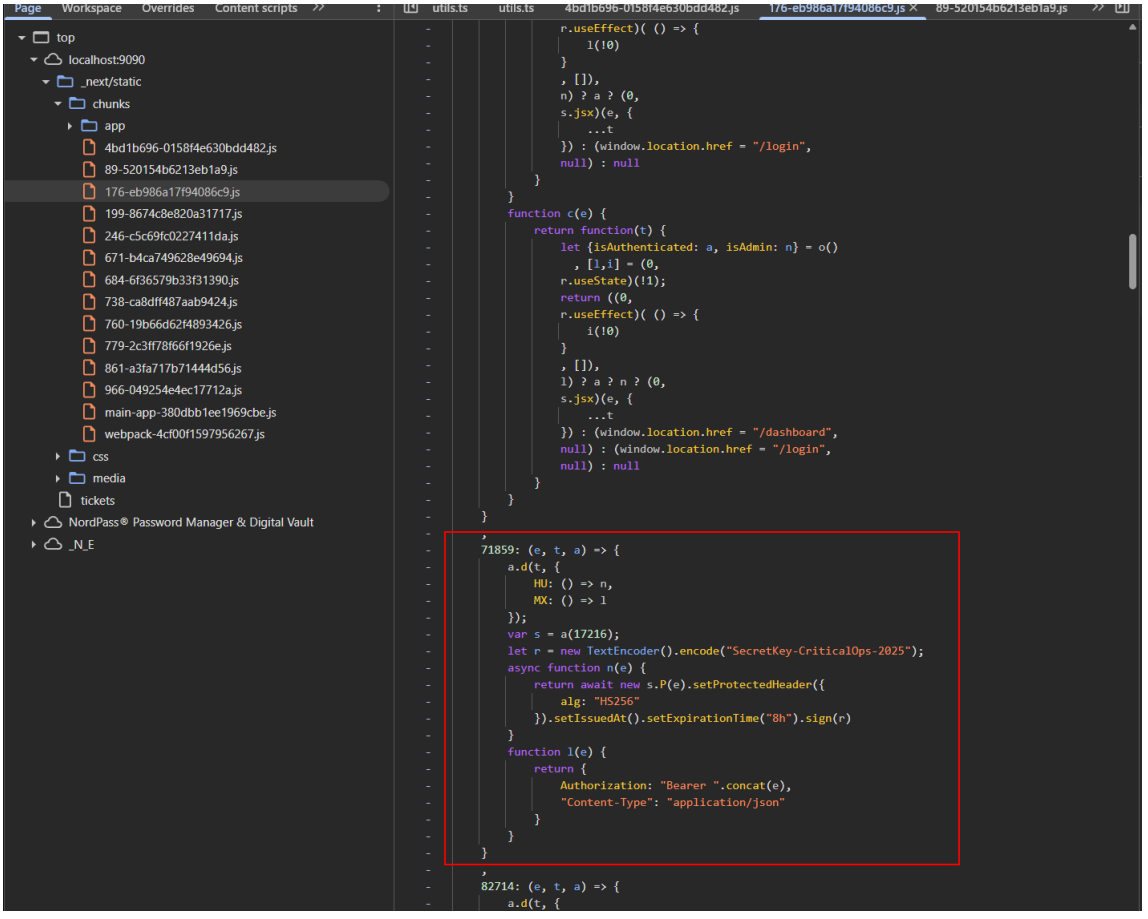


This raises a question: where is the token generated? Since there is no server-side token generation, the likely source is client-side code.

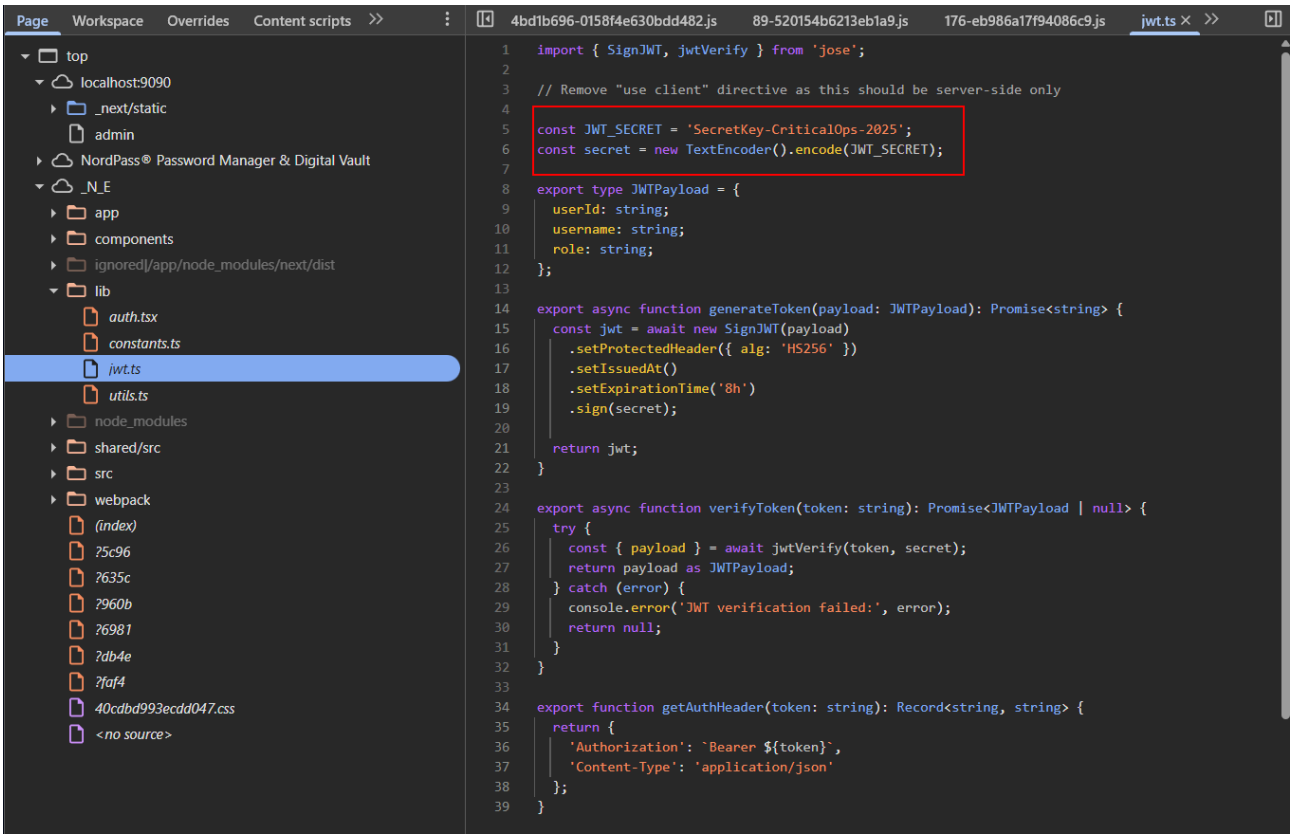
Inspecting the Sources tab in browser developer tools reveals a JavaScript file that contains the application's logic:



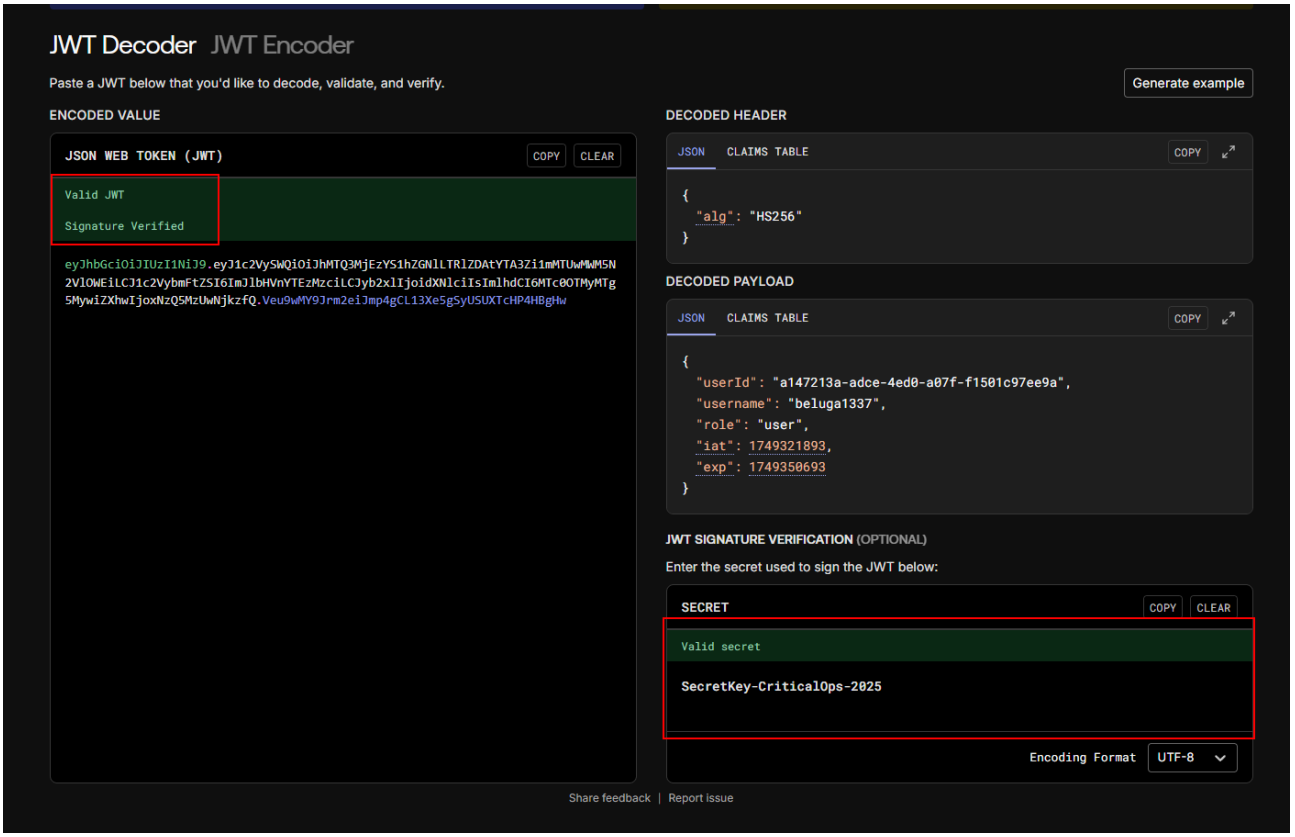
Scrolling through the code reveals suspicious strings and keys related to authorization:



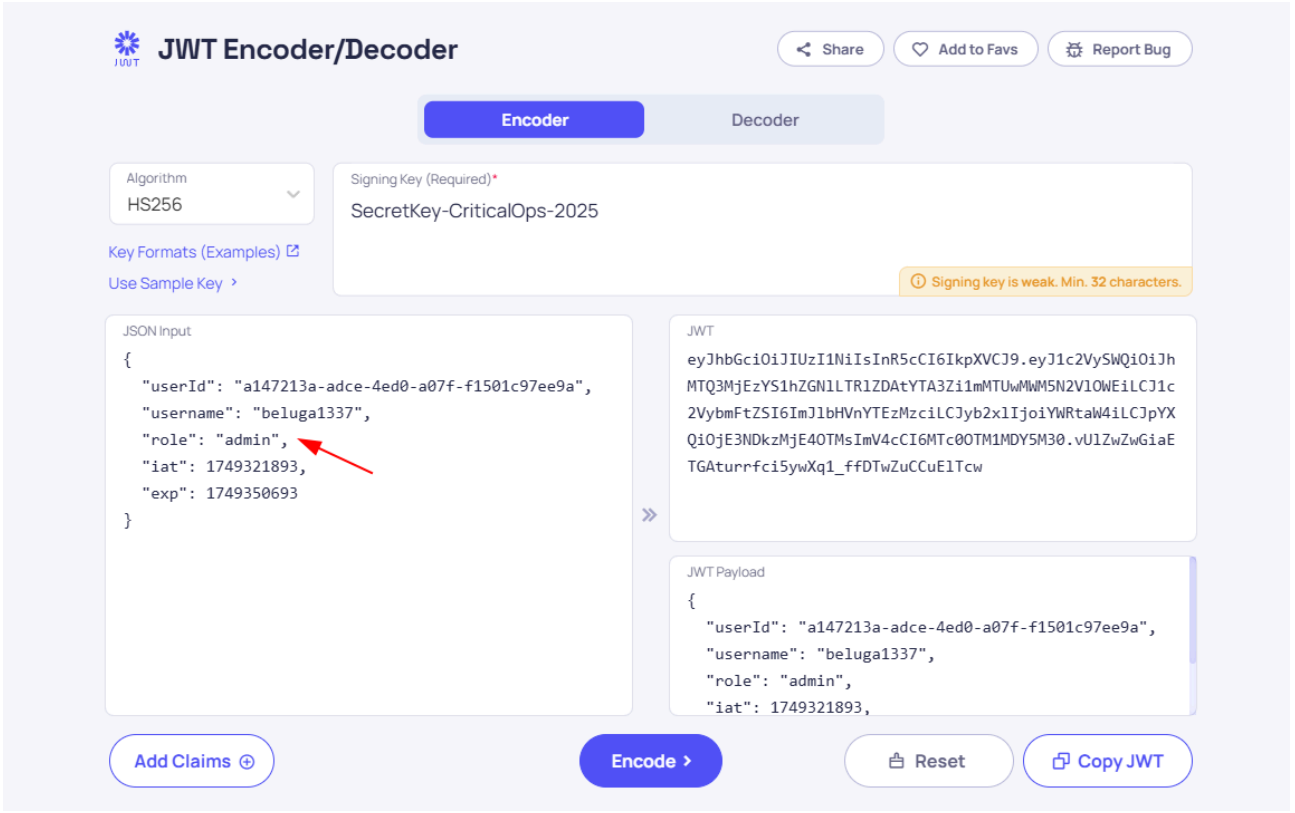
Another way to find the secret is through the source map:



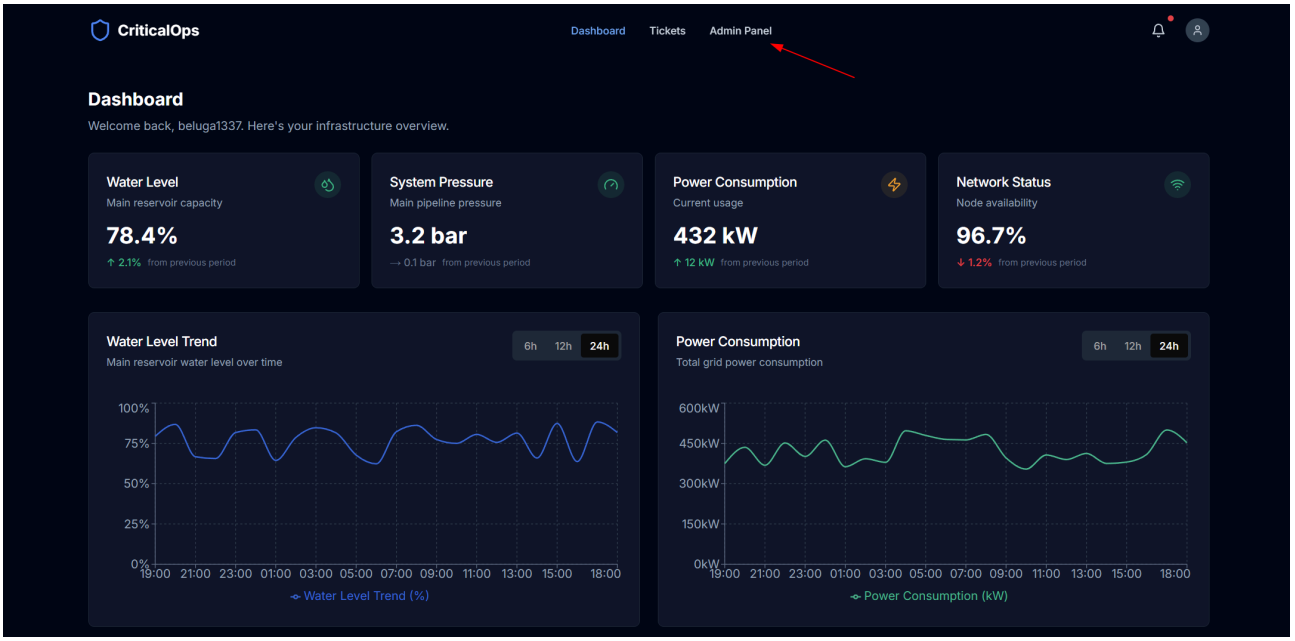
The exposed value is the JWT secret key used to generate the client-side token, and the token can be verified with that secret.



Using the secret key, craft a JWT and change the role to `admin`:



Next, place this forged token in both Local Storage and Cookies. Refreshing the page grants admin access:



With admin privileges, access the `Admin Panel` and retrieve the flag.